



PRE-LAUNCH REVIEW — CONFIDENTIAL

Nimbus Notes

Reviewed by Hamdi Hadrich · 2026-08-05 · commit reviewed: 9d4c1e2

What this review is. A heuristic review by reading. Not a security audit, not a penetration test, not a guarantee. It attests to the work done and the points checked — never that the application “is secure”.

Incident. live provider key found in history — client notified 2026-08-05, revocation advised

Three priorities

#	Check	What to do
1	Secrets	Revoke the key at the provider, not just delete it; purge the history; add a pre-commit secret scan.
2	Route auth	List every mutating route, then require authentication on the ones that are not public by design (signed webhooks, sign-up, sign-in).
3	Backups	Run a test restore into a throwaway instance, never into production, then schedule it quarterly.

The ten checks

Check	State	Finding	What to do
Secrets	RED	git history 4f1a9c — provider API key committed then removed (VALUE REDACTED)	see priority 1
.env hygiene	AMBER	.env gitignored, but no .env.example committed	Add a .env.example documenting the expected variables.
Route auth	RED	src/api/notes.ts:44 — DELETE /notes/:id with no caller check	see priority 2
Database exposure	NOT_VERIFYABLE	Config shows the app reaching the database over the internal network; whether the database also answers from the public internet lives in the provider's console, which was not opened during the interview. Recorded as unverifiable — silence is never scored as fine	Open the provider console's network tab: if an external IP allow-list is empty or absent, close it explicitly
Backups	RED	Backups configured but never restored	see priority 3
Uptime	AMBER	/health endpoint exists, no external ping	Add an external uptime probe that pings a human.
Error monitoring	GREEN	Sentry wired; last error captured a week ago	—
Rate limiting	AMBER	Throttle on /login, absent on public POST routes	Extend rate limiting to the public POST routes.
Dependencies	GREEN	package-lock.json present, versions recent	—
Cost guardrails	RED	No spend alert on the cloud account	Set a budget alert; decide who is paged at 10× normal traffic.

Investigation briefs. One brief per priority to hand to your AI agent — attached file *diligence-report-nimbus-notes-briefs.md*. It produces a plan, never a fix.

Attestation. A read-only review on a copy — no production system was touched, no flaw was exploited. No secret value appears in this report (locations only). The repository copy was deleted on delivery. Authorization: email 2026-08-04, reply “yes” (including point 4, the liability clause) — repo github.com/client/nimbus.